

Documento de Visão Geral: Challenge FIAP & PRIDE Security 2026

O Problema que Vamos Resolver

Hoje em dia, toda empresa quer usar Inteligência Artificial (como Copilot, ChatGPT & etc.) para programar mais rápido. O problema é que isso gerou um novo pesadelo de segurança:

1. **Vazamento de Dados:** Programadores colam senhas e códigos secretos na IA, e isso vaza na internet.
2. **Bibliotecas Infectadas:** Hackers colocam vírus em códigos gratuitos na internet. Quando o programador baixa, a empresa inteira é comprometida (Ataque de Cadeia de Suprimentos).
3. **A IA sendo Hackeada:** Invasores estão descobrindo como enganar a IA da própria empresa para que ela revele segredos ou libere acessos indevidos.

A Nossa Solução: Noxus ASPM 360°

Nós vamos criar uma plataforma que faz uso de uma equipe de IA agêntica (baseada em crewAI), que funciona como um escudo invisível ao redor do programador e da empresa. Ela não apenas vigia o código, mas usa Inteligência Artificial para agir como um mentor de segurança, automatizando recomendações e propostas de correção sem atrapalhar o trabalho de ninguém.

O projeto é dividido em 5 **pilares principais**:

1. O Cérebro Central (Dashboard)

Executivos e gerentes precisam de uma visão clara e consolidada.

- **O que é:** Um painel de controle (Dashboard) centralizado + Chatbot.
- **O que ele faz:** Ele junta os alertas de todas as ferramentas de segurança integradas (OWASP Dependency-Check, Nikto e Semgrep). As nossas IA's leem todos esses relatórios e alertas, apaga os que são falsos ou repetidos, e alerta a gestão apenas sobre os riscos reais e prioritários em cada aplicação. Além de

solicitar um feedback utilizado para refinamento contínuo dos modelos e regras de priorização. Tudo isso em conjunto com um chatbot que tem o intuito de ser usado para modelagem de riscos ainda nas etapas de idealização do projeto, e também para discutir melhorias e tirar dúvidas a respeito de alertas e propostas de correção.

2. O Guarda-Costas do Programador (DAST, SAST, SCA & SECRET SCANNING)

A ideia aqui é barrar o erro antes mesmo de ele ir de fato ao ar.

- **O que é:** Um agente que analisa o projeto em tempo real.
- **O que ele faz:** Se o desenvolvedor tentar por exemplo salvar um código com uma senha escrita direto no texto, ou com endpoints expostos e vulneráveis, o nosso sistema gera um alerta e aponta o erro, já oferecendo uma possível correção.

Como isso é feito? SAST: Será ligado ao repositório, e analisará cada commit, além de realizar verificações esporádicas verificando se CVE's recém-publicadas podem estar presentes no código. DAST: Realiza testes automáticos sobre aplicações em execução, simulando ataques reais para identificar vulnerabilidades, e assim que o relatório é gerado ele é enviado diretamente para o Cérebro Central. SCA: Será integrada ao ambiente de desenvolvimento através de APIs consumidas no próprio código do desenvolvedor e extensões IDE, verificando dependências e bibliotecas baixadas em tempo real, essa mesma API é quem notifica e alerta o Cérebro central. Secret scanning: Ele é o responsável por procurar, Tokens, Chaves, Credenciais e Senhas, expostas diretamente no código, fazendo isso com verificação dupla, sendo essa verificação tanto no repositório quanto durante o desenvolvimento na própria IDE via extensão. E por fim, uma de nossas IA's integradas irá analisar e correlacionar cada um dos relatórios gerados por essas ferramentas. Apontando todas as falhas, removendo falsos positivos, vulnerabilidades e alertas duplicados, e em conjunto com o alerta uma sugestão para a correção também, já é automaticamente enviada, com a mesma podendo ser discutida com nosso chatbot.

3. O Filtro da Internet (EXTENSÃO & API)

Não podemos confiar em códigos de terceiros sem validação.

- **O que é:** Uma extensão para IDE's ligada a API da nossa plataforma, que age como verificador automático de bibliotecas e dependências.
- **O que ele faz:** Quando o desenvolvedor tenta baixar uma biblioteca da internet para usar no projeto, nosso sistema pesquisa em bancos de dados globais de ameaças em tempo real. Se o código for malicioso ou vulnerável, ele na hora e avisa o Cérebro Central e emite um alerta.

4. O Escudo da Inteligência Artificial (Guardrails)

Se a empresa usa IA, nós precisamos proteger essa IA.

- **O que é:** Um filtro de segurança focado em conversas de IA (baseado nas regras mundiais da OWASP).
- **O que ele faz:** Fica no meio do caminho entre o usuário e a IA corporativa. Se alguém tentar mandar um comando malicioso para confundir a IA (Prompt Injection) ou tentar fazer a IA vaziar dados de clientes, o nosso escudo bloqueia a interação.

5. A equipe que não dorme (Agentes AI)

E enfim nosso diferencial, uma equipe de IA agentica composta por 5 agentes especializados, cada um responsável por uma função específica dentro do ecossistema de segurança do Noxus ASPM 360°.

- **O que é:** Uma arquitetura de IA agentica baseada em CrewAI, composta por agentes especializados que trabalham de forma coordenada para analisar riscos, correlacionar vulnerabilidades, priorizar alertas, auxiliar desenvolvedores e realizar refinamento contínuo da plataforma.
- **O que ele faz:** A equipe agentica é composta por 5 agentes de IA especializados:
 1. IA de Feedback e Refinamento
Seria o “Gestor” da equipe, responsável por coletar, analisar e distribuir os feedbacks enviados pelos clientes para os demais agentes da plataforma, permitindo refinamento contínuo das prioridades, recomendações e regras utilizadas pelas IA's.
 2. IA Chatbot de Segurança e Modelagem de Risco
Responsável pela interação com usuários, suporte técnico, modelagem de riscos durante a fase de idealização do projeto e auxílio na interpretação de alertas e sugestões de correção.
 3. IA de Correlação e Triagem de Relatórios
Responsável por correlacionar os relatórios gerados pelas ferramentas de

SAST, DAST, SCA e Secret Scanning, reduzindo alertas duplicados, identificando potenciais falsos positivos e consolidando os resultados em um relatório unificado priorizado através de uma matriz de risco.

4. IA de Recomendações e Resposta

Responsável por receber os relatórios unificados, analisar o contexto das vulnerabilidades identificadas e gerar automaticamente alertas acompanhados de sugestões contextualizadas de correção e mitigação.

5. IA de Alertas Emergenciais

Responsável por monitorar eventos críticos em tempo real, como upload de códigos contendo tokens, senhas, credenciais expostas ou detecção de bibliotecas e dependências maliciosas ou vulneráveis identificadas pela extensão integrada na plataforma de desenvolvimento.

O Modelo de Negócios

Para o desafio, nós não desenhamos apenas uma solução técnica, mas um produto pronto para o mercado corporativo:

- **SaaS por Ativos:** O modelo de cobrança será baseado no número de sistemas ou aplicativos que o nosso Noxus está monitorando. É um formato escalável, onde empresas maiores geram um ticket maior.
- **Compliance Integrado:** Grandes corporações exigem certificações de segurança (como a ISO 27001) para fechar negócios. O nosso sistema bloqueia vazamentos de dados e gera automaticamente os logs e relatórios de auditoria que essas normas exigem, tornando-se uma ferramenta de alto valor agregado.

As Ferramentas Que Vamos Usar (Tech Stack)

Para a execução técnica do projeto, utilizaremos o seguinte ecossistema:

- **Linguagem Base:** Python, devido à sua força em IA e segurança da informação.
- **O Painel e API:** FastAPI para construir um servidor rápido e assíncrono, e Streamlit para gerar o dashboard visual de forma ágil com Python.
- **O Motor de Inteligência Artificial:** Os modelos disponíveis “gratuitamente” pela OpenRouter.
- **Framework de Orquestração Agêntica:** CrewAI
- **Banco de Dados:** PostgreSQL, garantindo a integridade e segurança no armazenamento das vulnerabilidades descobertas.

- **Sugestão de uso:** Devido a extensão e a API, o noxus tem melhor compatibilidade e integração com ferramentas open-source, sugerimos para SAST: Semgrep. Dast: Nikto. SCA: OWASP dependency-check. Secret scanning: Gitleaks.